



KODIGO

Governance Artifacts & Full User Manual

Cloud-first point-of-sale, inventory, supplier, and analytics system

Document scope: Proposed business flow; COBIT-aligned permissions and accountability; ITIL-aligned escalation; full operating manual; AUP and BYOD policies; data classification; and a user-facing privacy notice.

Version 1.0 | 2 August 2026

Prepared for capstone evaluation and operational use

Document Control

Field	Value
System	Kodigo multi-store POS and inventory platform
Audience	Store administrators, cashiers, inventory staff, super administrators, and technical support
Owner	Kodigo System Owner / Store Administration
Approval	Capstone adviser and designated system owner
Review cycle	At least annually and after material role, privacy, or workflow changes
Source basis	Current React/Vite UI, Supabase migration chain through migration 28, and production operations runbook

How to Use This Document

Sections 1–3 are governance and service-management artifacts. Section 4 is the day-to-day manual. Sections 5–7 are policy and privacy artifacts that should be approved and adopted by the deploying organization before production use.

Implementation note: Kodigo is store-scoped. A user sees only stores assigned through membership mappings, and the selected active store controls operational context. The “All Stores” view is for aggregation and cannot process a sale.

Contents

- 1. Proposed Business Flow
- 2. COBIT Artifact — Permission Matrix & Roles and Responsibilities
- 3. ITIL Artifact — Escalation Path
- 4. Full Manual Guide
- 5. Acceptable Use and BYOD Policy
- 6. Data Classification Table
- 7. Privacy Notice
- Appendix A. Control and Evidence Notes

1. PROPOSED BUSINESS FLOW

1. Proposed Business Flow

From access provisioning to sale, stock control, reporting, and continual improvement

The proposed operating model starts with controlled onboarding and ends with review and corrective action. Each step protects the reliability of sales and inventory records while keeping frontline work fast enough for a busy small retailer.



8. Improve and govern

The System Owner reviews incidents, permissions, audit evidence, backup tests, and user feedback. Approved changes move through staging, testing, production deployment, and documented rollback procedures.

Why the Flow Matters

Control objective	How the flow supports it
Accuracy	Catalog setup precedes sales; checkout records item, payment, tax/discount snapshots, receipt, and stock effects as one controlled operation.
Accountability	Named users, roles, store membership, sale events, audit logs, and stock adjustment records show who did what and where.
Continuity	Offline queues keep authorized operations available during network interruption, while backups and rollback protect recovery.
Decision support	Current stock, supplier scoring, alerts, and reports convert transaction data into replenishment and performance decisions.

2. COBIT ARTIFACT — PERMISSION MATRIX & ROLES AND RESPONSIBILITIES

2. COBIT Artifact — Permission Matrix & Roles and Responsibilities

Least privilege, segregation of duties, ownership, approval, and accountability

Permission legend: Full Control = administer and configure; Edit = create/change operational records; Approve = authorize sensitive action; Read = view only; Execute = perform a narrow transaction; None = no access. All application access remains limited to assigned stores.

2.1 Functional Permission Matrix

Capability	Admin	Cashier	Inventory	Super Admin
POS checkout	Execute	Execute	None	None
Inventory products & stock	Full Control	Read at POS	Edit	None
Stock adjustments	Approve/Edit	None	Edit	None
Suppliers & purchase orders	Full Control	None	Read only where exposed	None
Dashboard & analytics	Full Control	None	None	None
Reports/export	Full sales + inventory	None	Inventory/stock only	None
Store settings & branding	Full Control	None	None	None
Manage store users	Full Control in shared stores	Own account only	Own account only	None
Invite-code governance	None	None	None	Full Control
Notifications	Store/admin notices	Operational notices only	Limited	System notices
Account password	Own account	Own account	Own account	Own account
Audit/error logs	Read scoped operational evidence	None	None	System governance view as configured

Important: Super Admin is a platform-governance role, not a tenant-store operator. It must not be used to bypass store-scoped controls. Inventory is a back-office role for inventory and inventory reporting; it is redirected away from POS and admin-only modules.

2.2 Environment Permission Matrix

Role	Production App/Data	Staging/Test	Source & CI	Edge Functions	Backups
Cashier	Execute POS in assigned store	Test user only when invited	None	None	None
Inventory	Edit inventory; inventory reports	Test user only	None	None	None

Role	Production App/Data	Staging/Test	Source & CI	Edge Functions	Backups
Admin / System Owner	Full tenant operations	Approve business acceptance	Read approved releases	None	Request restore; no direct vault access
Super Admin	Invite governance only	Validate invite workflow	None	None	None
System Administrator	Operational support; temporary audited elevation	Full technical control	Edit/deploy via approved change	Manage functions/secrets	Restore operator
IT Manager	Read/approve emergency access	Approve release	Approve merge/release	Approve privileged changes	Approve restore and retention
Developer	No routine access; time-bound support only	Edit	Edit via pull request	Deploy only if delegated	None
Privacy Contact / DPO	Read only when investigating a privacy case	None	None	None	Approve disclosure/deletion handling

2.3 Roles, Responsibilities, and Accountability

Role	Owns	Approves	Accountable when something goes wrong
Admin / System Owner	Store configuration, operational data quality, staff access, daily control review	User creation/removal, stock corrections, purchase orders, routine settings	Accountable for store impact, unauthorized access caused by poor provisioning, and business acceptance
Cashier	Accurate cart, payment, receipt, and end-of-shift reporting	Customer confirms tender; Admin approves void/refund exceptions	Accountable for transactions under own credentials and immediate reporting of discrepancies
Inventory Staff	Product master data, counts, stock adjustments, inventory reports	Admin approves unusual or high-impact adjustments	Accountable for count accuracy, reason codes, and supporting notes
Super Admin	Invite-code governance and platform onboarding controls	Approves/generates governed invite access	Accountable for invite misuse or excessive issuance within assigned authority
Store Team Lead	First-line incident intake, verification, workaround, and user communication	Escalates unresolved or multi-user problems	Accountable for complete ticket details and timely escalation
System Administrator	Availability, Supabase configuration, deployments, logs, restores, technical diagnosis	Implements approved normal changes; emergency action per incident authority	Accountable for technical recovery, change evidence, and privileged access records
IT Manager	Service ownership, risk acceptance, major-incident command, vendor coordination	Approves releases, emergency change, restore, and service communications	Ultimately accountable for service continuity and post-incident action
Privacy Contact / DPO	Rights requests, breach assessment, privacy advice, records of processing	Approves privacy response and disclosure decisions	Accountable for lawful, transparent, and timely privacy handling

2.4 Control Rules

- No shared accounts. Every action must be attributable to one named user.
- Access is granted by role and store membership, reviewed quarterly, and removed immediately on separation or role change.
- Privileged technical access is time-bound, ticketed, approved, and reviewed after use.

- The person implementing a high-risk change should not be the sole approver of that change.
- Audit logs are append-only evidence; corrections are recorded as new events rather than silent edits.

2.5 Quarterly Access Review Procedure

1. Admin exports or reviews the current user list, roles, active status, and store assignments.
2. Each Store Team Lead confirms which users still require access and whether duties changed.
3. Admin removes leavers, corrects excessive store scope, and records the approval/effective date.
4. System Administrator reviews privileged technical accounts, tokens, secrets, and emergency access evidence.
5. IT Manager signs off unresolved exceptions and assigns a due date; the review record is retained as audit evidence.

Approval Triggers Outside the Review Cycle

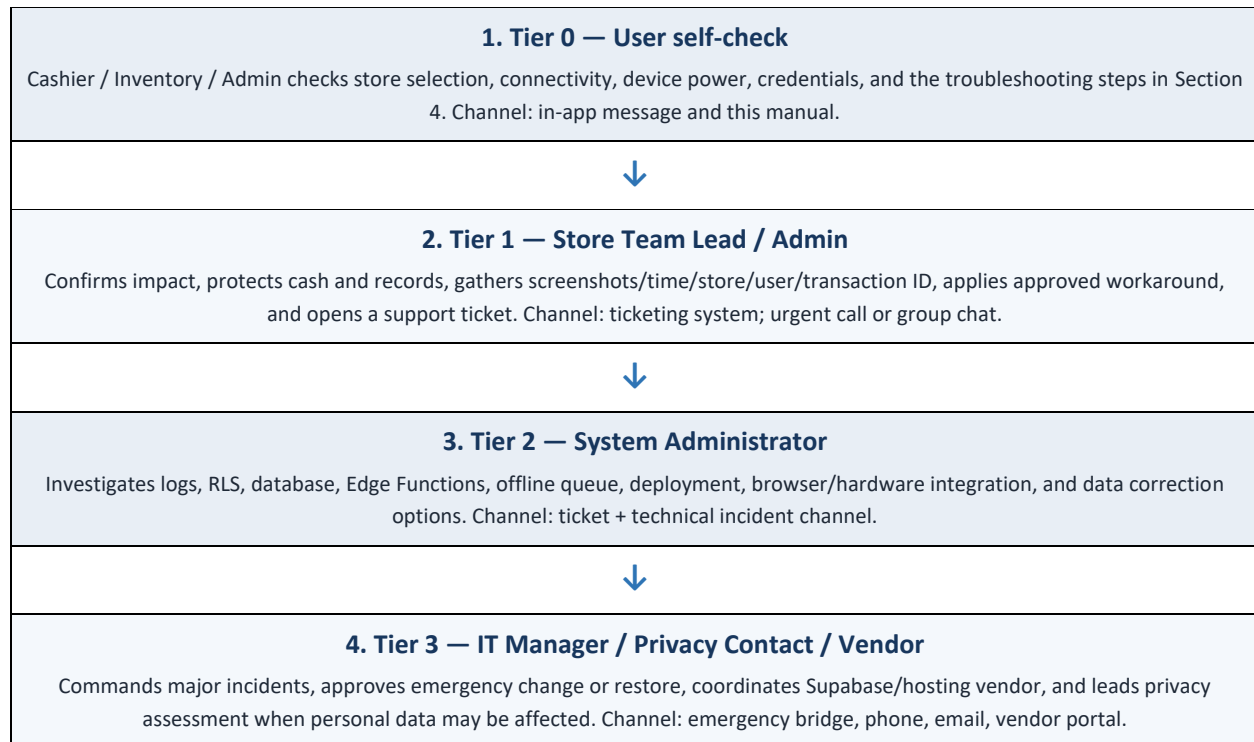
Immediate review is required after termination, transfer, suspected compromise, major incident, new store assignment, introduction of a new role, or a material RLS/route change. Emergency access expires when the incident ends and must not silently become permanent.

3. ITIL ARTIFACT — ESCALATION PATH

3. ITIL Artifact — Escalation Path

A practical service desk route tied to the roles and accountability model

3.1 Escalation Diagram



3.2 Tier Criteria and Targets

Tier	Escalate when	Response / resolution target	Channels	Role
Tier 0	Single-user usability issue; known warning; no data loss or security concern	Immediate / up to 10 min	Manual, in-app feedback	User
Tier 1	Issue persists after basic checks; cash discrepancy; one terminal/store affected; access request	Acknowledge 15 min (P1/P2), 1 business hr (P3); target workaround 1 hr	Ticket; urgent chat/call	Store Team Lead / Admin
Tier 2	Multiple users; repeated failed sync; suspected RLS/database defect; checkout unavailable; incorrect stock/sale state	Acknowledge 30 min; P1 restore/workaround target 4 hrs; P2 1 business day	Ticket + technical incident channel	System Administrator
Tier 3	Major outage, restore/emergency change, vendor dependency, confirmed/suspected breach, legal or reputational impact	P1 acknowledge 15 min; executive update every 60 min; recovery target set by incident commander	Emergency bridge/phone/email/vendor or portal	IT Manager; Privacy Contact for privacy

Targets are operational commitments for the capstone deployment and should be replaced by an approved service-level agreement if Kodigo is commercialized. Resolution depends on cause; when the target cannot be met, the owner must provide an updated estimate and workaround.

3.3 Severity Guide

Priority	Example	Action
P1 Critical	Checkout unavailable for a store/all stores; active security incident; material data corruption	Immediate Tier 2 and Tier 3; preserve logs; activate continuity process
P2 High	Major feature unavailable, repeated sync failures, wrong totals/stock affecting operations	Tier 1 validates, then Tier 2 within 15 minutes
P3 Normal	Single-user problem with workaround; report/export or noncritical device issue	Tier 1 ticket; escalate if unresolved within 1 business day
P4 Request	How-to question, enhancement, planned access or configuration change	Normal service request queue and change process

3.4 Required Ticket Information

- Reporter name and role; store and terminal; date/time and timezone.
- What the user attempted, expected result, actual result, and exact message.
- Transaction/receipt/product ID when applicable; never paste passwords or full payment credentials.
- Screenshot with unnecessary personal data redacted; browser/device and online/offline status.
- Business impact, number of users affected, workaround tried, and whether data or privacy may be at risk.

4. FULL MANUAL GUIDE

4. Full Manual Guide

Complete operating instructions for Kodigo's core workflows

4.1 Manual Rationale and Training Approach

This manual is for sari-sari store owners/administrators, cashiers, inventory staff, super administrators, and first-line support personnel using Kodigo across one or more branches. Their tasks differ, but they share the same operational data: a cashier's sale changes inventory; inventory changes affect checkout; and administrators use both to replenish and report.

A Full Manual is the right primary documentation type because the system combines routine high-frequency work with lower-frequency, higher-risk tasks. A quick-start guide would help with first login or checkout but would omit role boundaries, offline behavior, stock correction, reporting, escalation, and policy obligations. A video is harder to search during a live transaction and becomes stale whenever screens change. An interactive simulation is useful for practice but expensive to maintain and cannot serve as the authoritative control and troubleshooting reference. This manual remains searchable, printable, reviewable, and suitable for training and audit evidence.

Training should use a blended model: instructor-led onboarding for Admins and new Cashiers, a self-paced copy of this manual for reinforcement, and just-in-time checklists at the terminal. Instructor-led practice is appropriate for payment, void/refund, stock adjustment, and incident scenarios because mistakes affect cash and records. Self-paced review supports shift-based staff, while just-in-time steps reduce memory burden during real work. Competency should be demonstrated in a staging store before production access is granted.

Recommended training evidence: Record attendance, role assigned, practice scenarios completed, trainer sign-off, and date of refresher training. Re-train after major workflow or policy changes.

4.2 What Kodigo Does

Kodigo is a cloud-first, multi-store retail operations system. It supports checkout and receipts, inventory and stock adjustments, supplier and purchase-order management, stock alerts, dashboards, analytics, rankings, reporting, store branding, user management, notifications, and account security. Supabase provides authentication and store-scoped database access; IndexedDB supports selected offline queues; Web Serial can trigger a compatible cash drawer.

4.3 Before You Begin

- Use a supported modern browser. Cash-drawer Web Serial requires a compatible browser and HTTPS or localhost.
- Confirm the device clock, network, receipt printer/scanner connection, and correct store assignment.
- Use your own account. Do not share a password or leave an unlocked terminal unattended.
- For POS, select one specific active store. The All Stores view is for consolidated review only.

- Know your role: Cashier uses POS; Inventory manages products/stock and inventory reports; Admin manages store operations; Super Admin governs invites.

4.4 Sign In, Store Context, and Account Security

1. Open the Kodigo login page and enter your assigned email and password.
2. After login, verify the name/branding and active store shown in the interface. If you are assigned to several stores, choose the branch you are operating.
3. If you see no store or the wrong store, stop before posting data and ask the Admin to check membership.
4. To change your password, open Account Security, enter the current password, then a new password of at least eight characters and confirm it.
5. When finished, use Logout. Closing the browser alone is not a substitute on a shared device.

Password reset: Use Forgot Password from the login page or ask an Admin to send a managed-user reset. Support must never ask for the current password.

4.5 POS Checkout

1. Open POS Terminal and confirm the active store. Admin POS access is intended for desktop; Cashier is the frontline POS role.
2. Find an item by product name, SKU, or barcode. F2 focuses search. A compatible keyboard-emulating scanner can input the barcode.
3. Add the product to the cart. Adjust quantity only after physically confirming the requested amount and available stock. Numeric pre-entry can set a quantity multiplier.
4. Review product, quantity, unit price, subtotal, discount/tax presentation, and total. Remove accidental items before payment.
5. Select Charge or press F9 when the cart contains items. Choose the payment method and enter cash received where required.
6. Confirm the change due with the customer, then complete checkout once. Wait for confirmation—do not double-click or repeat a sale because the screen is slow.
7. Issue the generated receipt. If configured, print it and open the cash drawer through the approved hardware action.
8. If the sale is queued offline, note the terminal and time. Keep the browser data intact until synchronization succeeds.

Payment and Receipt Checks

- Cash: count tender aloud, confirm amount entered, and return the displayed change.
- GCash/card/bank transfer/other: record only the supported method/reference; do not store full card numbers, PINs, OTPs, or wallet passwords.
- Receipt: verify store identity, invoice/receipt number, items, totals, payment, cashier, date/time, and VAT/non-VAT information configured for the store.

Voids, Refunds, Returns, and Closeout

These actions affect revenue, stock, cash, and audit evidence. Follow the organization's approval threshold. The Cashier records the reason and requests Admin/Team Lead approval; the Admin verifies the original transaction and supporting facts. Never delete a transaction to hide an error. Kodigo's transaction lifecycle records status/events so corrections remain traceable.

4.6 Offline Operation and Synchronization

Kodigo caches products for offline POS lookup and can queue eligible offline sales and selected mutations in the browser's IndexedDB. When connection returns, focus/visibility/online events trigger synchronization and data revalidation.

1. If an offline message appears, confirm the correct store and continue only if the screen explicitly allows the operation.
2. Do not clear browser data, switch browser profiles, uninstall the browser, or use private mode while transactions are pending.
3. Reconnect to the approved network and leave Kodigo open. Allow the queue to replay and watch for success or rejection messages.
4. If an RLS/database error appears, do not repeatedly retry. Capture the message and escalate because business-rule errors are not safely queued as network failures.
5. Reconcile pending receipts and stock after synchronization. Escalate any duplicate, missing, or rejected sale immediately.

4.7 Inventory and Product Management

1. Open Inventory and select a specific store. Admin and Inventory roles can access this area.
2. To add a product, enter a unique SKU, optional barcode, product name, category, selling unit, cost, price, opening stock, low-stock threshold, reorder level, lead time, and supplier where applicable.
3. Review cost and selling price before saving. A wrong unit or conversion factor can distort stock and margin reports.
4. To edit, open the product, change only verified fields, and save. Avoid changing SKU/barcode identity during active checkout without coordination.
5. For stock changes, use Stock Adjustment rather than overwriting history. Enter the delta, reason, and a meaningful note; verify before/after quantities.
6. Delete/deactivate products only after checking links and operational need. Use the confirmation dialog and preserve history required for reports.

Bulk/per-piece selling: Stock is intended to be tracked in the smallest sellable unit. Validate purchase-unit conversion data before relying on it for production reports because optional conversion display fields may require deployment-specific verification.

4.8 Stock Alerts and Restocking

1. Review low, critical, and out-of-stock alerts from Notifications/Restocking.

2. Confirm physical count before ordering. The suggested quantity is a planning aid, not an automatic approval.
3. Review the proposed quantity, reorder level, lead time, recent sales, and supplier availability.
4. Create purchase orders grouped by supplier/store. Validate item, quantity, unit cost, supplier, and expected delivery.
5. Move the order through Sent, Received, or Cancelled status. Mark Received only after checking delivered goods and quantities.
6. Investigate supplier-score changes and delivery exceptions; add supporting records rather than changing history without explanation.

The current planning rule is: suggested quantity = $\max(\text{reorder level} \times 2 - \text{current stock}, \text{reorder level})$. Human review remains required because promotions, seasonality, shelf capacity, cash limits, and supplier constraints are not fully captured by the formula.

4.9 Suppliers

1. Open Suppliers and select the relevant store context.
2. Add or edit supplier name, contact person, phone/email/address, lead time, and related product information.
3. Use purchase-order and delivery history to evaluate reliability, price, and overall score.
4. Before deletion, check linked purchase orders. Retain records needed for financial, operational, or audit purposes.

4.10 Dashboard, Analytics, Rankings, and Reports

- Dashboard: reviews daily revenue, transaction count, average order value, estimated profit, recent transactions, and stock conditions.
 - Analytics: filters Today, 7, 30, or 90 days and analyzes revenue/profit, hourly sales, category sales, and recent transactions.
 - Rankings: aggregates sale items to rank products by sales activity. Use this instead of the dashboard Top Products panel when a sales-based ranking is required.
 - Reports: Admin can generate sales and inventory workbooks with date, payment, status, cashier, product, category, and selling-unit filters. Inventory can export inventory/stock-focused reports only.
1. Select one store or an authorized All Stores aggregate where the report supports it.
 2. Choose the date range and filters; refresh and review summary totals before export.
 3. Confirm status filters include/exclude voided or refunded transactions as intended.
 4. Export only to an approved location. Apply the data-classification rules in Section 6 and securely delete obsolete copies.

4.11 Store Settings, Branding, Users, and Notifications

- General/branding: Admin maintains store name, address, tax rate, registered/business name, TIN, branch code, VAT status, receipt label/prefix, terminal identifier, permits/accreditation text, contact details, and logo.
- Users: Admin can create, edit, reset, or remove Admin/Cashier/Inventory users only within shared assigned stores. Multi-store Admin assignments must be deliberate.

- Notifications: Admin can manage preferences for low stock, out of stock, daily summary, and sales milestones where configured.
- Super Admin: governs invite codes and system onboarding, not tenant operational CRUD.

User removal: Before removing or changing a user, verify identity, approval, active shifts, pending offline work, and store assignments. Access loss should be immediate, but operational records remain attributable to the former user.

4.12 Basic Troubleshooting

Problem	Likely cause	Safe action
Cannot sign in	Wrong password, reset required, missing profile/role	Retry carefully; use Forgot Password; ask Admin to confirm the account. Escalate if role cannot be resolved.
No store / wrong store	Missing membership or stale selection	Stop posting; refresh; re-login; ask Admin to verify store assignment.
POS unavailable	Role/device restriction, network, deployment	Cashier/Admin desktop only as allowed; check network; capture error; use approved continuity process.
Barcode not found	Wrong barcode, product inactive/missing, scanner mode	Search by name/SKU; verify product and scanner input; do not create duplicates.
Sale appears pending	Offline queue or slow connection	Do not repeat sale; reconnect and wait for sync; reconcile by receipt/time before retry.
Stock is incorrect	Unreceived PO, unsynced sale, wrong adjustment	Count physically; review sale/adjustment/PO history; Admin approves a documented correction.
Report totals differ	Store/date/status filter or pending sync	Confirm context and filters; sync; compare transaction statuses; escalate with export and IDs.
Cash drawer fails	Unsupported browser, insecure context, permission/cable	Use HTTPS/localhost and compatible browser; reconnect; allow permission after user gesture; use manual fallback.
Access denied/RLS error	Role/store policy blocks action	Do not bypass or keep retrying; verify assignment; send exact error to Tier 2.
App looks stale	Cached data or inactive tab	Bring tab to front, refresh, check online state, and re-login if safe; preserve pending offline data.

4.13 End-of-Shift Checklist

- Complete or cancel open carts; do not leave an ambiguous payment screen.
- Confirm pending offline transactions are synchronized or formally handed over.
- Perform the approved cashier closeout and explain any variance.
- Secure receipts/reports and remove customer-visible information from the counter.
- Log out, lock the device, and report unresolved incidents with ticket number to the next shift.

5. ACCEPTABLE USE AND BYOD POLICY

5. Acceptable Use and BYOD Policy

Adoptable policy text for Kodigo users and devices

5.1 Acceptable Use Policy (AUP)

Purpose

This policy protects Kodigo, the stores it supports, and the people whose information is processed. It establishes authorized, secure, and accountable use of the application, accounts, devices, network access, reports, and connected peripherals.

Scope

This policy applies to all employees, owners, contractors, students/testers, support personnel, and third parties who access Kodigo or its data in production, staging, test, backup, export, or support environments.

Allowed Uses

- Perform assigned retail, inventory, reporting, administration, support, or audit duties within the user's approved role and stores.
- Use authorized scanners, receipt printers, cash drawers, browsers, and networks for business operations.
- Create exports only for an approved business purpose and store them in an approved restricted location.
- Report errors, vulnerabilities, lost devices, suspicious access, and privacy concerns promptly through the escalation path.
- Use staging/test accounts and non-production data for training and testing whenever feasible.

Prohibited Uses

- Sharing accounts, passwords, reset links, OTPs, invite codes, service-role keys, or sessions; using another person's account; or leaving a terminal unlocked.
- Accessing another store, role, user record, report, or log without authorization, even if a technical path appears available.
- Changing, deleting, fabricating, or concealing sales, stock, supplier, user, receipt, closeout, error, or audit records to misrepresent events.
- Installing unapproved extensions/software; bypassing security controls; probing production; or connecting unknown USB/serial devices.
- Saving full card numbers, PINs, OTPs, wallet passwords, government IDs, or unrelated customer information in notes, logs, screenshots, or tickets.
- Uploading Kodigo data to personal email, public cloud storage, social media, public AI tools, or removable media without written approval.
- Clearing browser data when offline transactions are pending, or intentionally disrupting synchronization, backups, logging, or availability controls.

Consequences

Violations may result in immediate access suspension, preservation and review of relevant logs, corrective training, disciplinary action, contract consequences, recovery of losses where lawful, and referral to management, the Privacy Contact, law enforcement, or regulators as appropriate. Actions will be proportionate, documented, and consistent with applicable law and organizational rules.

CIA Triad linkage: The rule against credential sharing protects Confidentiality by limiting data to authorized users, protects Integrity by preserving reliable attribution, and supports Availability by reducing account compromise and service disruption.

5.2 Bring Your Own Device (BYOD) Policy

BYOD is applicable only when the organization expressly permits personal devices for Kodigo. A personal device is not automatically authorized merely because the web application can open on it.

Device Security Requirements

- Supported, legally licensed operating system and browser with automatic security updates enabled.
- Device passcode of at least six digits or strong password; biometric unlock may supplement but not replace the passcode.
- Automatic screen lock within five minutes; full-device encryption; active anti-malware where supported; firewall enabled.
- No rooted/jailbroken devices, unsupported operating systems, shared family profiles, or unapproved browser extensions.
- Use only trusted networks or an organization-approved VPN; public/shared Wi-Fi must not be used for administrative or export activity without protection.
- Do not locally save reports, receipts, screenshots, or credentials unless explicitly approved. Pending offline data must be synchronized promptly.
- Lost/stolen devices, suspected compromise, or unauthorized family/third-party access must be reported immediately and no later than one hour after discovery.

Support Boundaries

Support covers Kodigo configuration, supported browsers, approved scanner/printer/cash-drawer integration, and reasonable diagnosis. The organization does not guarantee support for personal hardware defects, data plans, home routers, unrelated apps, personal backups, or unsupported operating systems. Support may require the user to reproduce the issue on an organization-managed device.

Liability and Privacy

The device owner remains responsible for personal-device costs, lawful content, physical care, and personal backups. The organization is responsible for protecting Kodigo business data under its control but is not liable for ordinary loss of personal data caused by user failure to back it up, except where law or contract provides otherwise. Investigation and remote session revocation may affect Kodigo data or sessions; personal content will not be inspected beyond what is necessary and authorized for security, legal, or privacy response.

Offboarding and Device Disposal

1. Admin removes or changes Kodigo access and store assignments on the effective separation/role-change date.
2. User logs out, removes saved credentials/bookmarks that reveal restricted endpoints, and synchronizes or hands over pending authorized work.
3. System Administrator revokes active sessions/tokens where available and confirms no pending offline queue remains on the device.
4. User securely deletes approved local exports, receipts, caches, and screenshots; Admin verifies completion through an offboarding checklist.
5. Before selling, recycling, or transferring the device, the owner performs a secure factory reset after preserving lawful personal backups.

Exceptions and Acknowledgment

Any exception must identify the business need, data involved, compensating controls, owner, approval, and expiry date. The IT Manager approves security exceptions; the Privacy Contact also approves exceptions involving personal data. Unapproved exceptions are policy violations.

User acknowledgment	Record
I understand that Kodigo access is limited to my role and assigned stores.	Name / signature / date
I will report loss, compromise, incorrect records, or pending offline work promptly.	Training record or policy acceptance
I consent to proportionate security controls on authorized BYOD access and will complete offboarding.	Device ID and approval expiry

6. DATA CLASSIFICATION TABLE

6. Data Classification Table

Inventory of Kodigo data and minimum protection expectations

Classification uses three practical labels: Personal Data (PD), Sensitive Personal Information (SPI), and Operational/Non-personal (OP). Credentials and security telemetry may not always fall within a statutory SPI category, but Kodigo treats them as Restricted because compromise creates significant risk. Customer identity is not required for ordinary cash sales; do not collect it unless a defined feature and lawful purpose require it.

Data item	Classification	Protection	Minimum controls
User name, profile ID, avatar	PD	Confidential	Store-scoped access; authenticated use; correct/erase through Admin/privacy process
User email and phone (if used)	PD	Confidential	Use for account/contact only; mask in tickets and exports; encrypted transit/storage
Password/authentication tokens	PD (security credential)	Restricted	Supabase Auth only; never public tables/logs; no sharing; reset and revoke on compromise
Role and store memberships	PD	Confidential	Least privilege; Admin shared-store scope; quarterly review and immediate offboarding
IP address, browser/device, error context	PD when linkable	Confidential	Collect only for security/support; restrict logs; time-limited retention
Government identifiers if later collected	SPI	Highly Restricted	Do not collect by default; documented legal basis, encryption, narrow access, retention limit
Health/biometric information	SPI	Highly Restricted	Not required by Kodigo; prohibited unless separately approved and lawfully implemented
Store TIN, permit/accreditation details	OP; may become PD for sole proprietor	Confidential	Admin-only edit; controlled receipt display; accurate and current
Store name, address, contact, branding	OP / possible PD	Internal–Confidential	Admin control; publish only intended receipt/contact fields
Products, SKU/barcode, cost, price, stock	OP	Confidential	Store-scoped RLS; change history/adjustments; backups
Supplier contact person, email, phone, address	PD + OP	Confidential	Business-purpose use; store scope; limit exports and deletion to retention rules
Sales, sale items, totals, discounts, tax	OP; PD if linked to person	Confidential	Store scope; append-only lifecycle evidence; financial retention; encrypted transfer
Payment method/reference	PD/financial context when linkable	Restricted	Never store full card/PIN/OTP; mask reference; narrow access and retention
Receipts/invoice numbers	OP; may contain PD	Confidential	Issue to customer; protect duplicate copies/exports; approved retention
Stock adjustments and creator label	PD + OP	Confidential	Named attribution, reason/note, immutable audit trail, store scope
Purchase orders and supplier scores	OP; may contain PD contacts	Confidential	Admin scope; accuracy review; protected exports
Audit logs, error logs, sale events, closeouts	PD + OP	Restricted	Append-only; Admin/technical need-to-know; monitor access; defined retention
Backups and exported reports	Same as source data	Restricted	Encrypted/restricted vault; restore testing; minimum 30-day backup retention per runbook; controlled disposal

Data item	Classification	Protection	Minimum controls
Invite codes and reset links	PD/security secret	Restricted	Single-purpose, limited validity/use, never public or reused, revoke when exposed

Handling Rules by Protection Level

Level	Handling rule
Internal	Authenticated business use; share only within the organization for a legitimate task.
Confidential	Role/store-scoped access, encrypted transfer, approved storage/export, logged changes, secure disposal.
Restricted / Highly Restricted	Named need-to-know access, no casual export, additional approval, monitoring, short retention where feasible, immediate incident response.

Retention and Disposal Baseline

Record group	Baseline decision
Sales, receipts, tax and payment records	Retain for the approved financial/legal period; lock against routine deletion; dispose securely when authorized.
User/account and membership records	Retain while active plus the period needed for audit or claims; revoke access immediately on offboarding.
Audit, error and security logs	Keep long enough to investigate incidents and demonstrate control operation; restrict and purge on an approved schedule.
Exports and screenshots	Keep only for the specific task; delete from downloads, email, chat, and removable media when the task/retention need ends.
Backups	Minimum 30-day restricted retention per current runbook, subject to the production backup plan and legal requirements.

7. PRIVACY NOTICE

7. Privacy Notice

Short notice for Kodigo account holders and business contacts

Plain-language notice: This notice should be displayed at account creation or made accessible from the login/settings area. The deploying organization is the personal information controller and must insert its legal name and any legally required registration details before publication.

1. What we collect

We collect account details such as your name, email, role and assigned store; activity records such as sales, stock adjustments, reports and audit events; and limited device/error information needed to secure and support Kodigo. Ordinary cash sales do not require customer identity.

2. Why we use it

We use the information to authenticate users, operate store transactions and inventory, issue receipts, manage staff access, produce reports, prevent misuse, troubleshoot errors, meet recordkeeping duties, and improve service reliability. We will not use it for an unrelated purpose without notice and an appropriate lawful basis.

3. How we protect and share it

Access is limited by role and assigned store, protected by authentication, encrypted connections, row-level security, logs, backups, and controlled support access. We share data only with authorized personnel and service providers needed to run or support Kodigo, subject to appropriate safeguards and legal requirements.

4. Your choices and rights

Subject to applicable law, you may ask to access or correct your data, object to or restrict certain processing, request deletion when retention is no longer required, withdraw consent where processing relies on consent, and raise a complaint. We may verify identity and retain records required for security, transactions, or law.

5. Contact us

Send privacy questions or requests to the Store Administrator / Privacy Contact using the official store email shown in Kodigo Settings and on the store receipt. If unavailable, submit a support ticket marked “Privacy Request.” Do not include passwords, OTPs, or unnecessary identity documents in the first message.

Privacy Principles Applied

Principle	How it is applied
-----------	-------------------

Principle	How it is applied
Collection limitation	Kodigo collects only data needed for accounts, store operations, security, support, and required records; customer identity and SPI are not required by default.
Purpose specification	The notice states the operational, access-control, reporting, security, support, and recordkeeping purposes at collection.
Use limitation	Data is not used or disclosed for unrelated purposes without notice, authority, and safeguards; access is role/store-scoped.
Transparency	Users are told what is collected, why, how it is protected/shared, their rights, and how to contact the responsible organization.

Privacy Request Handling

1. Log the request and acknowledge it through an approved channel without asking for unnecessary identity documents.
2. Verify the requester proportionately, identify the relevant stores/systems, and preserve required transaction or security records.
3. The Privacy Contact decides the lawful response, coordinates Admin/System Administrator action, and records any limitation or refusal reason.
4. Provide the response securely and record completion, disclosure recipients, corrections, deletions, or follow-up commitments.

Privacy incident: If data may have been accessed, changed, lost, or disclosed without authority, preserve evidence and escalate directly to Tier 3. Do not notify affected people or external parties without the Privacy Contact/incident commander's coordinated decision.

APPENDIX A. CONTROL AND EVIDENCE NOTES

Appendix A. Control and Evidence Notes

Technical anchors used to tailor this document to the current Kodigo implementation

Area	Repository evidence	Document implication
Application and routes	kodigo-ui/src/App.tsx; Sidebar.tsx; types/index.ts	Admin, Cashier, Inventory, Super Admin; route guards and module visibility
Authentication and tenancy	kodigo-ui/src/stores/authStore.ts; migration chain	Supabase Auth, profiles, store_users, active store, row-level security
POS and offline	cartStore.ts; transactions.ts; offline-sync.ts; hardware.ts	Checkout, queued sales/mutations, network-vs-database errors, cash drawer
Inventory/suppliers/reporting	productStore.ts; supplierStore.ts; reporting.ts; relevant pages	Product/stock, supplier/PO, reports and exports
Production controls	docs/production-ops.md; migrations 18–28	Backups, restore, deployment, rollback, audit/error logs, user RBAC hardening

Deployment Decisions Still Required

- Insert the deploying organization’s legal identity and official Privacy Contact details before publishing the privacy notice.
- Approve concrete service hours, incident targets, access-review frequency, export retention, and legal record-retention schedule.
- Confirm the supported invite-generation path, production environment ownership, backup subscription/retention, and vendor escalation contacts.
- Validate selling-unit conversion reporting and every policy/role against the exact production migration state before go-live.

Approval Record

Role	Name	Signature	Date
System Owner			
IT Manager / Technical Adviser			
Privacy Contact			
Capstone Adviser			